

Лабораторная работа №3

Кибербезопасность предприятия

Еюбоглу Т, Зиязетдинов А, Исаев Б | НПИбд-01-22

Содержание

1	Цель работы	5
2	Теоретическое введение	6
3	Выполнение лабораторной работы	7
3.0.1	4.1 SQL-инъекция	7
3.0.2	4.2 Последствие Web portal meterpreter	9
3.0.3	4.3 Отключенная защита антивируса	10
3.0.4	4.4 Последствие Admin meterpreter	12
3.0.5	4.5 Слабый пароль учетной записи	13
3.0.6	4.6 Последствие AD User	14
4	Вывод	16
	Список литературы	17

Список иллюстраций

3.1	Поиск места уязвимого параметра	7
3.2	Параметры уязвимой функции	8
3.3	Параметры уязвимой функции	9
3.4	Список установленных соединений	9
3.5	Завершение сессии с нарушителем	9
3.6	Удаление записи DisableAntiSpyware в реестре	10
3.7	Интерфейс Windows Defender	11
3.8	Включение Real-time Protection	12
3.9	Соединение с машиной нарушителя	13
3.10	Изменение пароля администратора	14
3.11	Удаление пользователя hacker в AD User & Computers	15

Список таблиц

1 Цель работы

Изучить сценарий атаки внешнего злоумышленника на контроллер домена предприятия с целью получения доступа к внутренним ресурсам компании. Освоить методы обнаружения, анализа и устранения последствий компьютерных атак с использованием программного комплекса “Empire”, включая выявление уязвимостей, таких как SQL-инъекция, отключенная защита антивируса и слабые пароли, а также их последствия.

2 Теоретическое введение

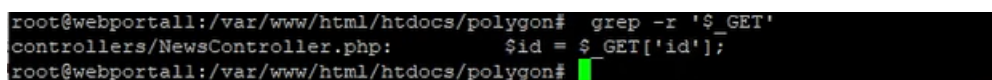
Внешний злоумышленник находит сайт компании в интернете и проводит атаку на него для получения доступа к внутренним ресурсам. Обнаружив уязвимости на внешнем периметре, закрепляется на сервере и проводит разведку сети для захвата контроллера домена. Нарушитель обладает средней квалификацией, умеет использовать инструменты для атак и техники постэксплуатации, а также имеет опыт фишинговых рассылок.

Для прохождения сценария потребуется exploitation уязвимостей, таких как SQL-инъекция, отключение антивирусной защиты, использование слабых паролей и получение доступа к Active Directory.

3 Выполнение лабораторной работы

3.0.1 4.1 SQL-инъекция

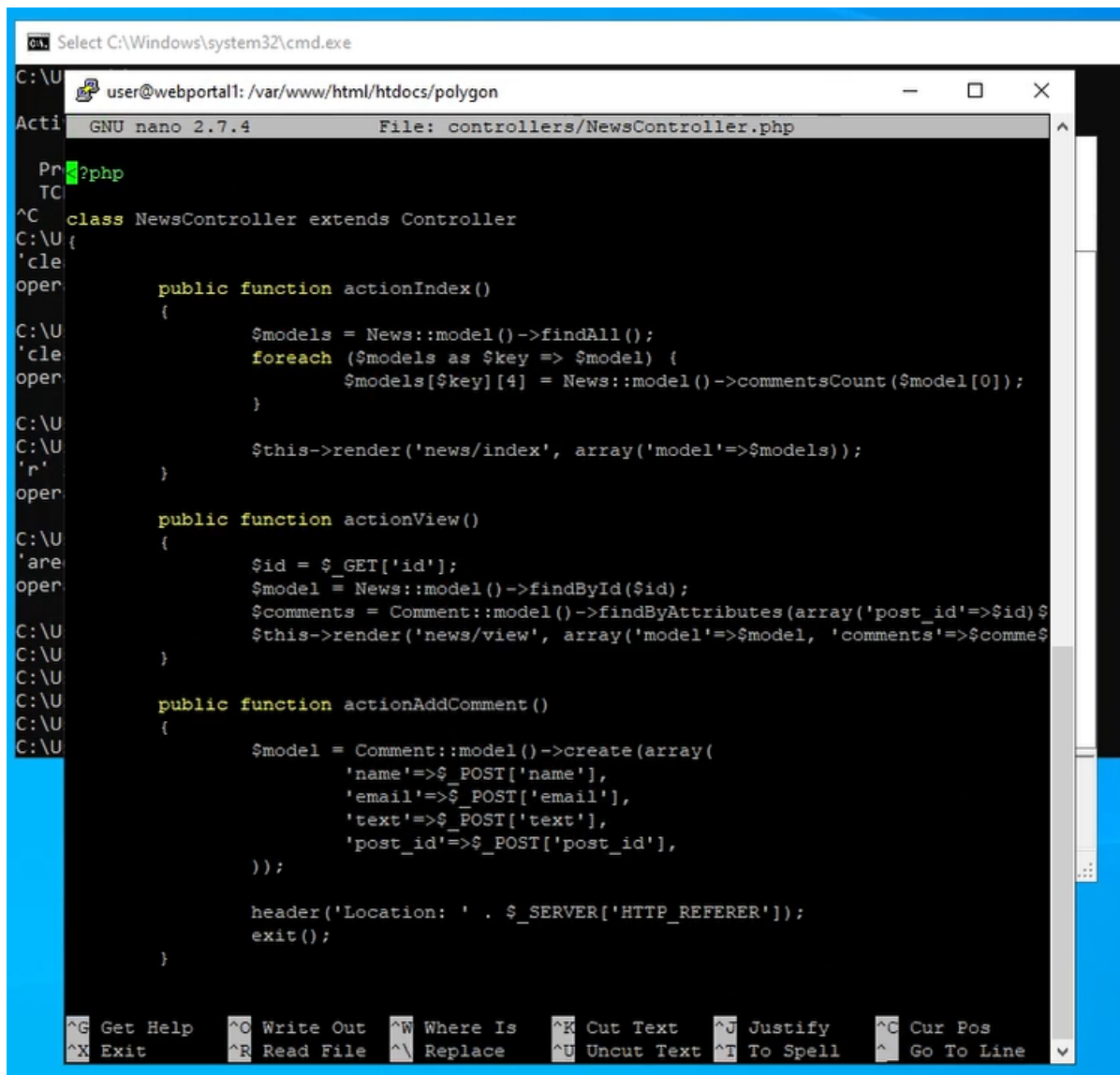
В ходе лабораторной работы была исследована уязвимость SQL-инъекции на веб-сервере PHP (узел Web Server PHP, порт 80). Злоумышленник сканирует сеть 195.239.174.0/24, находит веб-сервер и использует утилиту sqlmap для обнаружения уязвимого параметра (id) в запросе GET. С помощью sqlmap генерируется и загружается вредоносный файл php reverse shell (shell.php), что позволяет выполнить код на сервере и установить meterpreter-сессию для закрепления. Для детектирования использовались инструменты ViPNet IDS NS и Security Onion (Sqert, Kibana), где фиксировались события сканирования на SQL-инъекции, использование Blind SQL-Injection и загрузка файла с выставлением прав на выполнение (chmod). Устранение: В файле NewsController.php в функции actionView() добавлена проверка типа параметра \$id с помощью is_numeric(). Если \$id не является числом, запрос становится статичным. После изменений уязвимость устранена, повторное сканирование sqlmap не выявляет проблем. (рис. fig. 3.1).



```
root@webportall:/var/www/html/htdocs/polygon# grep -r '$_GET'
controllers/NewsController.php:         $id = $_GET['id'];
root@webportall:/var/www/html/htdocs/polygon#
```

Рис. 3.1: Поиск места уязвимого параметра

Считывание параметра сайта происходит в функции actionView() в файле NewsController.php (Рисунок 2)



```
C:\Windows\system32\cmd.exe
C:\U user@webportal1: /var/www/html/htdocs/polygon
GNU nano 2.7.4 File: controllers/NewsController.php
Pr ?php
TC
^C
C:\U class NewsController extends Controller
C:\U {
C:\U 'cle
C:\U oper
C:\U     public function actionIndex()
C:\U     {
C:\U         $models = News::model()->findAll();
C:\U         foreach ($models as $key => $model) {
C:\U             $models[$key][4] = News::model()->commentsCount($model[0]);
C:\U         }
C:\U         $this->render('news/index', array('model'=>$models));
C:\U     }
C:\U     public function actionView()
C:\U     {
C:\U         $id = $_GET['id'];
C:\U         $model = News::model()->findById($id);
C:\U         $comments = Comment::model()->findByAttributes(array('post_id'=>$id));
C:\U         $this->render('news/view', array('model'=>$model, 'comments'=>$comments));
C:\U     }
C:\U     public function actionAddComment()
C:\U     {
C:\U         $model = Comment::model()->create(array(
C:\U             'name'=>$_POST['name'],
C:\U             'email'=>$_POST['email'],
C:\U             'text'=>$_POST['text'],
C:\U             'post_id'=>$_POST['post_id'],
C:\U         ));
C:\U         header('Location: ' . $_SERVER['HTTP_REFERER']);
C:\U         exit();
C:\U     }
^G Get Help ^O Write Out ^W Where Is ^K Cut Text ^U Justify ^C Cur Pos
^X Exit ^R Read File ^\ Replace ^U Uncut Text ^T To Spell ^_ Go To Line
```

Рис. 3.2: Параметры уязвимой функции

Для проверки типа `$id` используется функция `is_numeric`, которая возвращает `True` в случае, если `$id` – число, иначе – `False`. В случае успешной проверки параметр `$id` будет передаваться в запрос, иначе – запрос будет статичным и независимым от `$id` (Рисунок 3).


```

public function actionView()
{
    $id = $_GET['id'];
    if (!is_numeric($id)) {
        $id = 1;
    }
    $model = News::model()->findByid($id);
    $comments = Comment::model()->findByAttributes(array('post_id'=>$id));
    $this->render('news/view', array('model'=>$model, 'comments'=>$comments));
}

public function actionAddComment()
{

```

Рис. 3.3: Параметры уязвимой функции

3.0.2 4.2 Последствие Web portal meterpreter

Нарушитель устанавливает shell сессию с веб-порталом РНР. Для обнаружения последствия необходимо проверить сокет уязвимой машины при помощи утилиты ss с ключами -tp (Рисунок 4).

```

root@webportall:/var/www/html/htdocs/polygon# ss -tp
State      Recv-Q Send-Q Local Address:Port      Peer Address:Port
ESTAB      0      0      10.10.1.20:45326        195.239.174.11:4444
users: (("chisel.sh",pid=10995,fd=3), ("sh",pid=10994,fd=3), ("gFTZfb",pid=989
2,fd=3))
ESTAB      0      272     10.10.1.20:ssh         10.10.1.253:23052
users: (("sshd",pid=24046,fd=4), ("sshd",pid=24037,fd=4))
ESTAB      0      0      10.10.1.20:40790       195.239.174.11:1085
users: (("chisel.sh",pid=10995,fd=11))
ESTAB      0      0      10.10.1.20:53238       10.10.1.25:5044
users: (("filebeat",pid=698,fd=5))
ESTAB      0      0      10.10.1.20:tpoxy       10.10.1.253:4037
users: (("server",pid=620,fd=8))
ESTAB      0      0      10.10.1.20:33178       10.10.2.17:25004
users: (("epp_agentd",pid=30816,fd=36))
root@webportall:/var/www/html/htdocs/polygon# ss -K dst

```

Рис. 3.4: Список установленных соединений

Для устранения необходимо воспользоваться командой ss (Рисунок 8) с правами привилегированного пользователя, используя ключ -K и соответствующий адрес, порт для завершения сессии с нарушителем: `sudo ss -K dst HACKER_IP dport = HACKER_PORT`

```

root@webportall:/var/www/html/htdocs/polygon# ss -K dst '195.239.174.11' dport = 4444
Netid State Recv-Q Send-Q Local Address:Port      Peer Address:Port
tcp    ESTAB  0      0      10.10.1.20:45326        195.239.174.11:4444
root@webportall:/var/www/html/htdocs/polygon#

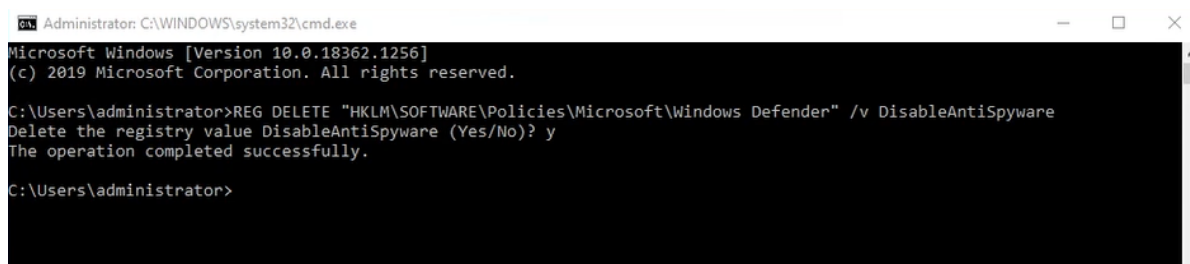
```

Рис. 3.5: Завершение сессии с нарушителем

В результате выполнения команды сессия с нарушителем завершена, последствие Web portal meterpreter успешно устранено.

3.0.3 4.3 Отключенная защита антивируса

На узле администратора выключена защита в реальном времени Windows Defender, что дает нарушителю возможность получить контроль над компьютером администратора при запуске им вредоносного скрипта diag.ps1



```
Administrator: C:\WINDOWS\system32\cmd.exe
Microsoft Windows [Version 10.0.18362.1256]
(c) 2019 Microsoft Corporation. All rights reserved.

C:\Users\administrator>REG DELETE "HKLM\SOFTWARE\Policies\Microsoft\Windows Defender" /v DisableAntiSpyware
Delete the registry value DisableAntiSpyware (Yes/No)? y
The operation completed successfully.

C:\Users\administrator>
```

Рис. 3.6: Удаление записи DisableAntiSpyware в реестре

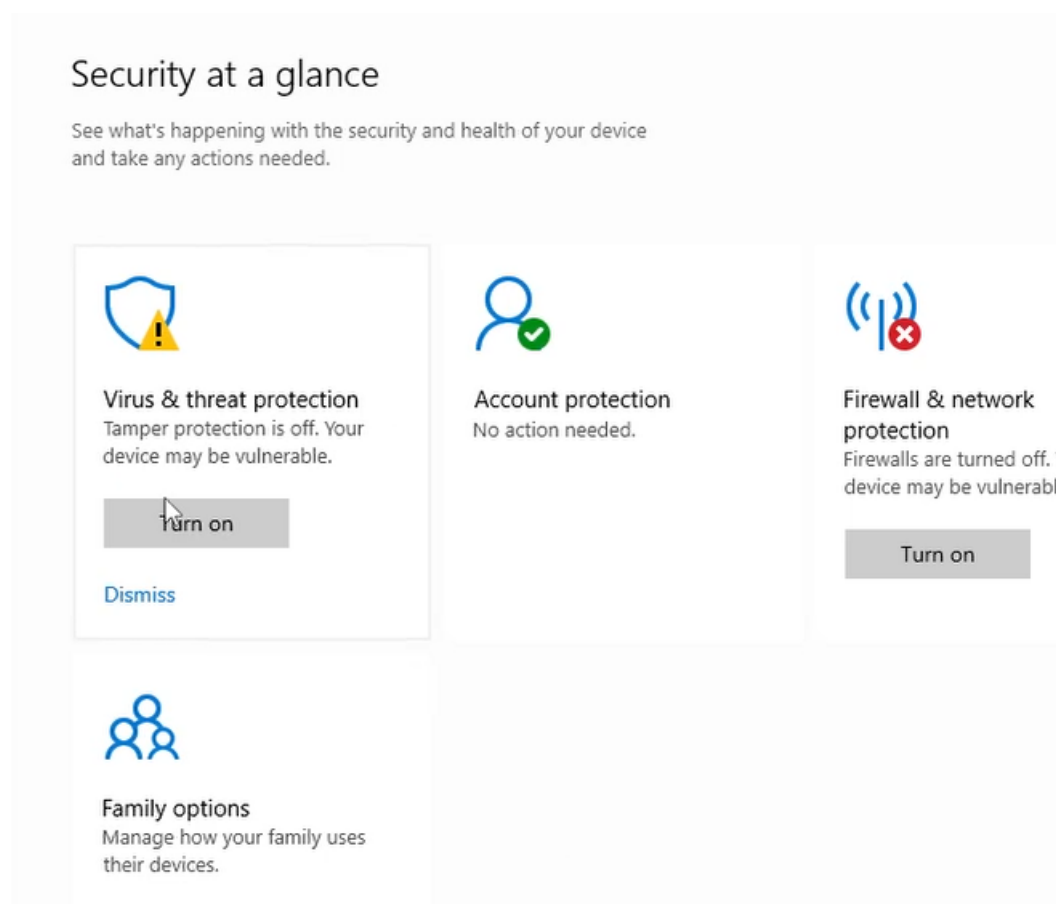


Рис. 3.7: Интерфейс Windows Defender

Virus & threat protection

Protection for your device against threats.

Current threats

No current threats.

Last scan: Not available

Quick scan

[Scan options](#)

[Allowed threats](#)

[Protection history](#)

Virus & threat protection settings

No action needed.

[Manage settings](#)

Virus & threat protection updates

Security intelligence is up to date.

Last update: Not available

[Check for updates](#)

Рис. 3.8: Включение Real-time Protection

После удаления записи реестра и включения защиты антивирусной программы Microsoft Defender необходимо перезагрузить Windows.

3.0.4 4.4 Последствие Admin meterpreter

Установленную сессию с нарушителем можно обнаружить при помощи утилиты netstat с ключами -ano

```

Administrator: Windows PowerShell
PS C:\Users\administrator> netstat -ano | more
Active Connections

```

Proto	Local Address	Foreign Address	State	PID
TCP	0.0.0.0:135	0.0.0.0:0	LISTENING	980
TCP	0.0.0.0:445	0.0.0.0:0	LISTENING	4
TCP	0.0.0.0:3389	0.0.0.0:0	LISTENING	1072
TCP	0.0.0.0:5040	0.0.0.0:0	LISTENING	6648
TCP	0.0.0.0:49664	0.0.0.0:0	LISTENING	720
TCP	0.0.0.0:49665	0.0.0.0:0	LISTENING	544
TCP	0.0.0.0:49666	0.0.0.0:0	LISTENING	1552
TCP	0.0.0.0:49667	0.0.0.0:0	LISTENING	1356
TCP	0.0.0.0:49669	0.0.0.0:0	LISTENING	2636
TCP	0.0.0.0:49671	0.0.0.0:0	LISTENING	3248
TCP	0.0.0.0:49672	0.0.0.0:0	LISTENING	720
TCP	0.0.0.0:49709	0.0.0.0:0	LISTENING	3164
TCP	0.0.0.0:49721	0.0.0.0:0	LISTENING	712
TCP	10.10.4.10:139	0.0.0.0:0	LISTENING	4
TCP	10.10.4.10:3389	10.10.4.12:58951	ESTABLISHED	1072
TCP	10.10.4.10:49670	10.10.2.10:445	ESTABLISHED	4
TCP	10.10.4.10:49673	10.10.2.10:135	TIME_WAIT	0
TCP	10.10.4.10:49674	10.10.2.10:135	TIME_WAIT	0
TCP	10.10.4.10:49675	10.10.2.10:135	TIME_WAIT	0
TCP	10.10.4.10:49676	10.10.2.10:135	TIME_WAIT	0
TCP	10.10.4.10:49677	10.10.2.10:49671	TIME_WAIT	0
TCP	10.10.4.10:49678	10.10.2.10:49671	TIME_WAIT	0
TCP	10.10.4.10:49679	10.10.2.10:49671	TIME_WAIT	0
TCP	10.10.4.10:49680	10.10.2.10:49671	TIME_WAIT	0
TCP	10.10.4.10:49696	10.10.2.10:135	TIME_WAIT	0
TCP	10.10.4.10:49697	10.10.2.10:49671	TIME_WAIT	0
TCP	10.10.4.10:49738	195.239.174.12:443	TIME_WAIT	0
TCP	10.10.4.10:49739	195.239.174.12:443	TIME_WAIT	0
TCP	10.10.4.10:49740	195.239.174.12:443	TIME_WAIT	0
TCP	10.10.4.10:49741	195.239.174.12:443	TIME_WAIT	0
TCP	10.10.4.10:49742	195.239.174.12:443	TIME_WAIT	0
TCP	10.10.4.10:49745	10.10.4.13:139	TIME_WAIT	0
TCP	10.10.4.10:49753	195.239.174.12:443	TIME_WAIT	0
TCP	10.10.4.10:49754	195.239.174.12:443	TIME_WAIT	0
TCP	10.10.4.10:49755	195.239.174.12:443	TIME_WAIT	0
TCP	10.10.4.10:49758	195.239.174.12:443	TIME_WAIT	0
TCP	10.10.4.10:49759	195.239.174.12:443	TIME_WAIT	0
TCP	10.10.4.10:49765	195.239.174.12:443	TIME_WAIT	0
TCP	10.10.4.10:49766	195.239.174.12:443	TIME_WAIT	0
TCP	10.10.4.10:49767	10.10.2.15:80	TIME_WAIT	0
TCP	10.10.4.10:49768	195.239.174.12:443	TIME_WAIT	0
TCP	10.10.4.10:49769	10.10.2.15:80	TIME_WAIT	0
TCP	10.10.4.10:49770	10.10.2.15:80	TIME_WAIT	0
TCP	10.10.4.10:49771	195.239.174.12:443	TIME_WAIT	0
TCP	10.10.4.10:49772	195.239.174.12:443	TIME_WAIT	0

Рис. 3.9: Соединение с машиной нарушителя

Для устранения необходимо завершить сессию с машиной нарушителя. Например, при помощи команды `taskkill /f /pid`

3.0.5 4.5 Слабый пароль учетной записи

На узле MS Active Directory установлен слабый пароль к учетной записи администратора, что позволяет нарушителю перебирать пароль

```
PS C:\Users\administrator> net user Administrator *
Type a password for the user:
Retype the password to confirm:
The passwords do not match.

Type a password for the user:
Retype the password to confirm:
The command completed successfully.

PS C:\Users\administrator> _
```

Рис. 3.10: Изменение пароля администратора

3.0.6 4.6 Последствие AD User

Добавление нового привилегированного пользователя можно отследить с помощью аудита событий входа в учетную запись Windows security, где появится событие с ID 4720. Необходимо перейти в Event Viewer и в Windows Logs – Security, затем применить фильтр на логи. Ниже показан лог, генерируемый при добавлении нового пользователя (Рисунок 16).

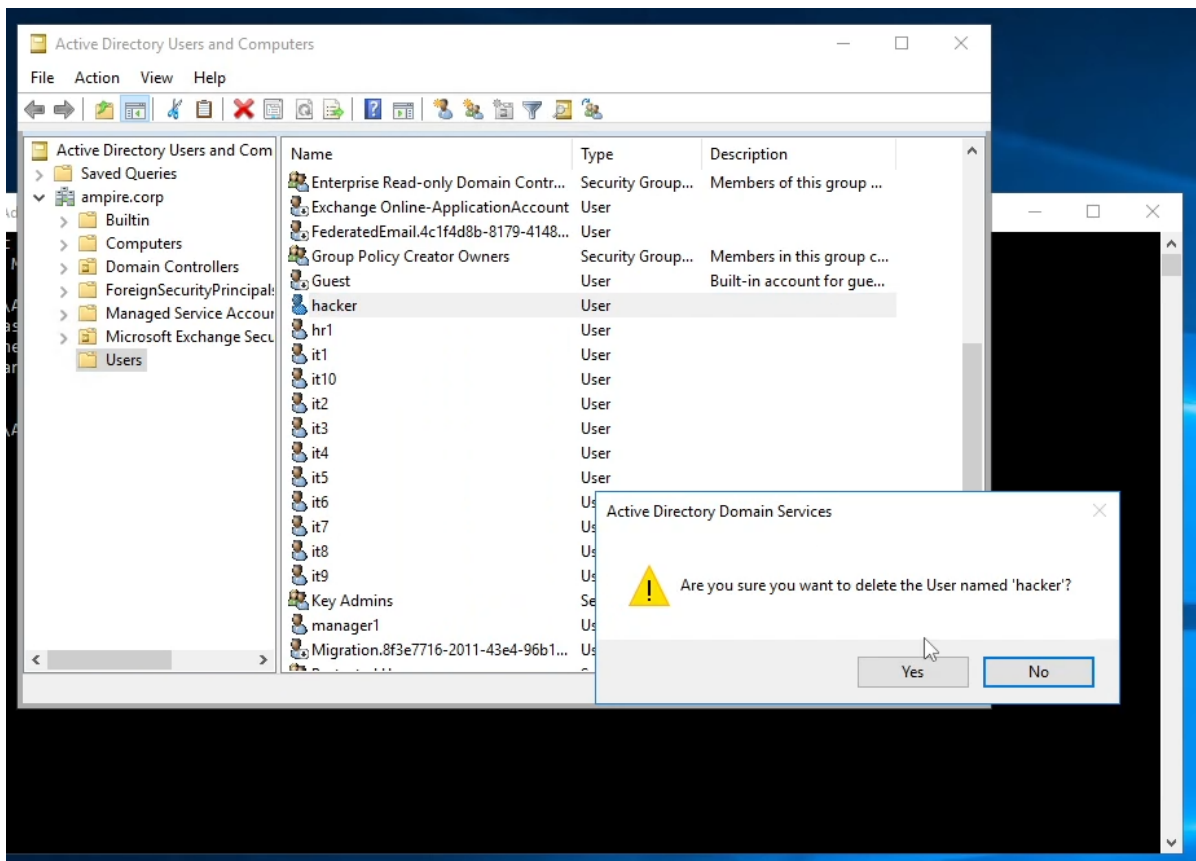


Рис. 3.11: Удаление пользователя hacker в AD User & Computers

В результате выполнения вышеупомянутых действий Киберполгон Ampire привилегированный пользователь удален, последствие AD User успешно устранено.

4 Вывод

В ходе лабораторной работы был изучен сценарий атаки на контроллер домена предприятия с использованием уязвимостей SQL-инъекции, отключенной антивирусной защиты и слабых паролей. Освоены методы детектирования атак с помощью ViPNet IDS NS, ViPNet TIAS и Security Onion, а также способы устранения последствий. Полученные навыки позволяют эффективно защищать корпоративные сети от внешних угроз средней сложности.

Список литературы